ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA1406 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I D Chand Basha (192424218) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

1. One-line email authorization with no scope

If a company only provides a vague one-line email authorization without a clearly defined scope, you must not exploit systems outside of explicit authorization. Ethical hacking is built on three pillars: authorization, scope, and rules of engagement. Exploiting a vulnerability in a system not mentioned in the email would violate scope and could expose you to legal liability under computer misuse laws.

Instead, the correct course of action is:

- **Stop testing that system immediately.**
- **Document the observation** (e.g., "During testing, I noticed a critical vulnerability in System X, which was not included in the authorized scope.").
- **Report it to the client** and request clarification or expanded authorization.

This protects you legally and ethically. Exploiting without permission—even with good intentions—would classify you as a gray hat, which is legally perilous. Ethical hacking requires explicit, documented authorization before touching any system.

2. SQL injection on a production database with real financial data

When testing a production database containing sensitive customer financial data, you must apply the principle of non-destructive testing. Exploiting SQL injection directly on live data risks corruption, leakage, or downtime.

The correct approach:

- **Use safe payloads** that demonstrate vulnerability without extracting or altering sensitive records (e.g., using SELECT 1 or metadata queries instead of dumping tables).
- **Conduct testing in a controlled environment** (preferably a staging or test database with dummy data).

Precautions that should have been taken before engagement:

- **Data handling agreements**: Define how sensitive data will be treated, retained, or destroyed.

- **Rules of engagement**: Explicitly state whether production systems can be tested and under what limits.
- **Fail-safe procedures**: Ensure backups and rollback plans exist in case of accidental disruption.

Ethically, you must minimize harm while still proving the vulnerability. The safest path is to demonstrate exploitability without touching real customer data.

3. Accidental denial-of-service during black-box test

Triggering a denial-of-service (DoS) on a live production server is a serious incident. Preventing this requires risk assessment and controlled testing methods:

- Before testing, you should have clarified scope and limitations (e.g., "DoS testing is prohibited on production systems").
- Use rate-limited scans and simulation tools instead of aggressive payloads.
- Always test potentially disruptive exploits in a sandbox or staging environment first.

Now that the outage has occurred, your responsibility is:

- **Immediately stop the test.**
- **Report the incident transparently** to the client, explaining what caused the outage.
- **Assist in recovery** (help restore services, provide logs, and cooperate fully).
- **Document lessons learned** to prevent recurrence.

Ethically, you must accept responsibility. Hiding the incident or downplaying it would violate integrity and accountability principles.

4. Client insists IT department not be informed

If a client asks you to test systems without informing their IT department, the risks are significant:

- **Ethical risk**: You may be perceived as an attacker if IT staff detect your activity, leading to false alarms or even law enforcement involvement.
- **Practical risk**: IT staff may take defensive actions (blocking IPs, shutting down systems) that disrupt operations.
- **Legal risk**: Without clear documentation, you could be accused of unauthorized access.

To protect yourself:

- **Insist on written authorization** that explicitly states IT staff will not be informed.
- **Define scope and escalation procedures** (e.g., if IT detects you, management must intervene).

- **Use controlled red team methodology**: Simulate real-world attacks but ensure safety nets (e.g., agreed “kill switch” if systems are at risk).

Ethically, you must balance realism with safety. A red team exercise can test detection capability, but it must be structured with **clear rules of engagement** and legal safeguards.

5. Red team vs. vulnerability assessment (Bank scenario)

A vulnerability assessment and a red team exercise differ in scope, ethics, and methodology:

- **Vulnerability Assessment (Bank example)**:
    - Goal: Identify and document technical weaknesses (e.g., outdated software, misconfigurations).
    - Approach: Run scans, perform controlled exploits, and report vulnerabilities.
    - Ethics: Focus on transparency, minimal disruption, and clear remediation guidance.
    - Rules of engagement: Limited to systems explicitly authorized, no social engineering or physical intrusion.
- **Red Team Exercise (Bank example)**:
    - Goal: Simulate a real-world adversary to test both physical and digital defenses.
    - Approach: Attempt phishing employees, tailgating into secure areas, exploiting network vulnerabilities, and testing incident response.
    - Ethics: Must be carefully scoped to avoid harm (e.g., no actual theft of money, no permanent damage).
    - Rules of engagement: Broader, but still explicitly documented. Includes escalation paths if critical systems are impacted.

For example, in a bank:

- A vulnerability assessment might reveal that the ATM software is outdated and vulnerable to buffer overflow.
- A red team exercise might simulate a criminal group attempting to gain physical access to ATM maintenance ports, exploit the software, and test whether the bank’s security team detects and responds.

Ethically, the difference is intent and scope: vulnerability assessments are diagnostic, while red team exercises are adversarial simulations. Both require explicit authorization, clear boundaries, and strong reporting integrity.